

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ
ИТМО
ITMO University

Практическая работа №8

По дисциплине Информационная безопасность

Тема работы Социальная инженерия

Обучающийся Сакулин Иван Михайлович

Факультет Факультет прикладной информатики

Группа К3321

Направление подготовки 11.03.02 Инфокоммуникационные технологии и
системы связи

Образовательная программа Программирование в инфокоммуникацион-
ных системах

Обучающийся

(дата)

(подпись)

Сакулин И.М.

(Ф.И.О.)

Руководитель

(дата)

(подпись)

Пикуль А.С.

(Ф.И.О.)

СОДЕРЖАНИЕ

Стр.

ВВЕДЕНИЕ	3
1 ХОД РАБОТЫ.....	4
1.1 Сбор артефактов.....	4
1.2 Разбор приёмов.....	4
1.3 Разбор известной атаки	8
ЗАКЛЮЧЕНИЕ	10
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ	11
ПРИЛОЖЕНИЕ А Артефакты.....	12

ВВЕДЕНИЕ

Социальная инженерия представляет собой получение информации или действий от человека путём манипуляции, а не техническим взломом. Общая схема атаки включает разведку, выбор легенды, установление контакта по выбранному каналу и побуждение жертвы к целевому действию. Манипуляция обычно опирается на несколько психологических рычагов одновременно: авторитет, срочность, страх, жадность, любопытство, социальное доказательство.

Цель работы — научиться распознавать приёмы социальной инженерии: разобрать реальные фишинговые сообщения.

Для работы были собраны реальные сообщения мошеннического или подозрительного характера из собственных источников: папок «Спам» электронной почты моей и моих знакомых и телеграм-группы.

1 ХОД РАБОТЫ

1.1 Сбор артефактов

Всего собрано восемь артефактов: семь писем электронной почты и одно сообщение в телеграм-группе. Для каждого артефакта зафиксированы канал, дата, отправитель и текст; скриншоты приведены в приложении.

- 1) Email, 25.08.2026, отправитель `webmaster@rightfast.com` — письмо-активация аккаунта с внедрённым посторонним текстом о выигрыше (рисунок А.1).
- 2) Email, 11.09.2026, отправитель `sales@biomagneticjewelry.com` — рекламная рассылка (рисунок А.2).
- 3) Email, 10.09.2026, отправитель `info@psicodisejconsulting.com` — автоответ с внедрённым текстом о денежном переводе (рисунок А.3).
- 4) Email, 14.09.2026, отправитель `fhuedcf@gta5lamadjo.ru` — сообщение с рекламой казино в формате переписки (рисунок А.4).
- 5) Email, 25.08.2026, отправитель `info@drone-kyoto.jp` — автоответ формы обратной связи с внедрённым текстом о розыгрыше от маркетплейса (рисунок А.5).
- 6) Email, 19.08.2026, отправитель `info@drone-kyoto.jp` — повторное письмо той же серии, вторая волна (рисунок А.6).
- 7) Email, 19.08.2026, отправитель `info@drone-kyoto.jp` — повторное письмо той же серии, третья волна (рисунок А.7).
- 8) Telegram, группа общежития, отправитель `@Alino4kaManager` — сообщение об обязательном вступлении в стороннюю группу (рисунок А.8).

1.2 Разбор приёмов

Результаты разбора психологических рычагов и технических маркеров сведены в таблицу 1.

Таблица 1 — Разбор артефактов социальной инженерии

№	Канал	Легенда отправителя	Психологические рычаги	Технические маркеры	Целевое действие
1	Email	Письмо-активация аккаунта на сайте winterhaven.ca с внедрённым в тему и текст сообщением о выигрыше	Жадность, любопытство, псевдоавторитет сервиса регистрации	From webmaster@rightfast.com, Return-Path указывает на platformsh.site и sendgrid.info, тема не соответствует содержанию письма, ссылка сокращена через share.google	Переход по ссылке активации с внедрённым текстом
2	Email	Рекламная рассылка ювелирного магазина BioMagneticJewelry	Взаимность, слабо выраженная жадность	Return-Path mlsend.com не совпадает с доменом компании, ссылки заменены плейсхолдерами, персонализация отсутствует	Переход по ссылке рассылки, отписка

Продолжение таблицы 1

№	Канал	Легенда отправителя	Психологические рычаги	Технические маркеры	Целевое действие
3	Email	Автоответ психологической консультации на обращение клиента	Жадность, любопытство	Return-Path cloud.xtudiocreativo.cloud не совпадает с доменом From, SPF не подтверждён, посторонний текст внедрён в заголовок шаблона, ссылка share.google	Переход по ссылке о зачислении средств
4	Email	Личное сообщение о выигрыше в казино, оформленное как переписка	Симпатия, социальное доказательство, жадность, срочность	Домен gta5lamadjo.ru не связан с темой сообщения, признаки массовой рассылки: маркировка 18+, ссылка на отписку	Переход по ссылке, внесение депозита
5	Email	Автоответ формы обратной связи компании drone-kyoto.jp	Жадность, любопытство	Return-Path указывает на общий хостинговый адрес, не связанный с доменом From, посторонний текст внедрён в поля формы, ссылка share.google	Переход по ссылке за призом

Продолжение таблицы 1

№	Канал	Легенда отправителя	Психологические рычаги	Технические маркеры	Целевое действие
6	Email	Повторное письмо той же серии, вторая волна	Срочность, страх упустить приз, авторитет	Технические маркеры совпадают с п. 5	Переход по ссылке, подтверждение участия
7	Email	Повторное письмо той же серии, третья волна	Срочность, давление повторной рассылкой	Технические маркеры совпадают с п. 5	Переход по ссылке до истечения срока
8	Telegram	Сообщение от лица администрации, требующее вступления в стороннюю группу	Авторитет, страх, обязательность, социальное доказательство	Ссылка на нестандартный домен webgu-max.live, маскирующийся под мессенджер «Макс», отправитель без признаков официального статуса	Переход по ссылке, вступление в группу

В выборке преобладают два рычага: жадность и авторитет. Жадность присутствует в шести случаях из восьми и опирается на обещание денег, выигрыша или бонуса. Авторитет использован в четырёх случаях из восьми и заключается в имитации официального источника: сервиса регистрации, маркетплейса, администрации учебного заведения.

Отдельно отмечается техника, использованная в артефактах 3, 5, 6 и 7. Вместо отправки письма с поддельного домена посторонний текст внедряется в форму обратной связи легитимной организации, после чего организация сама рассылает автоответ с этим текстом внутри. Такое письмо проходит проверки SPF и DKIM, поскольку отправлено реальным сервером компании, что снижает эффективность стандартных технических фильтров.

Наиболее убедительным в выборке является артефакт 8. Он сочетает авторитет (ссылка на распоряжение руководства учебного заведения), обязательность и страх, связанный с последствиями для отсрочки от военной службы, а также социальное доказательство за счёт распространения внутри закрытой студенческой группы. В отличие от прямого предложения выигрыша данный сценарий описывает конкретную и правдоподобную для адресата угрозу. Важно, что в первые секунды прочтения письма возникало ощущение что-то с этим сделать, однако, сообщение сразу показалось подозрительным, а ссылка веселья ради была проверена в *virustotal*: это оказался фишинг.

1.3 Разбор известной атаки

В 2016 году Эрик Спрингер описал случай социальной инженерии, связанный со службой поддержки Amazon. Злоумышленник выдавал себя за владельца аккаунта и с помощью полученных из открытых источников сведений смог получить дополнительную персональную информацию жертвы [1].

- 1) **Разведка.** Атакующий заранее узнал имя и адрес электронной почты жертвы, а также нашёл в открытом доступе адрес, связанный с её доменом. Эти сведения использовались для того, чтобы убедительно представить себя владельцем аккаунта.
- 2) **Легенда.** Злоумышленник представился самым клиентом Amazon, у которого возникла проблема с аккаунтом. Легенда выглядела правдо-

подобно, поскольку атакующий располагал реальными персональными данными и обращался через официальный канал поддержки.

- 3) **Точка входа.** Первоначальным каналом стал онлайн-чат со службой поддержки Amazon. Атакующий назвал имя и электронную почту жертвы и использовал известный ему адрес для прохождения проверки. После этого сотрудник поддержки сообщил настоящий адрес доставки заказа и номер телефона клиента.
- 4) **Эскалация.** Полученные данные позволили атакующему расширить объём доступной информации. В дальнейшем он неоднократно обращался в службу поддержки и пытался получить дополнительные сведения, в том числе данные банковской карты. По словам Спрингера, полученная информация также использовалась при обращении в его банк.
- 5) **Результат и ущерб.** В результате социальной инженерии были раскрыты персональные данные клиента, которые не должны были сообщаться постороннему лицу. Основная проблема заключалась в том, что каждая раскрытая деталь могла использоваться для последующих атак на другие сервисы.
- 6) **Точка отказа.** Атаку можно было остановить на этапе проверки личности. Одного имени, электронной почты и адреса недостаточно, если эти сведения можно найти в открытом доступе. Для чувствительных операций необходим дополнительный независимый фактор подтверждения, например код через уже привязанное устройство. Кроме того, служба поддержки не должна раскрывать персональные данные в процессе самой проверки личности.

Этот случай показывает, что социальная инженерия может использовать не техническую уязвимость, а недостаток в рабочей процедуре. Атакующему не требовалось взламывать Amazon: достаточно было убедительно выдать себя за клиента и заставить сотрудника поддержки самостоятельно раскрыть информацию. [1]

ЗАКЛЮЧЕНИЕ

В ходе работы я пришёл к выводу, что социальная инженерия работает даже против технически грамотных людей, поскольку атакует не столько знания пользователя, сколько его привычки, доверие и рабочие процессы. Человек может знать основные признаки фишинга, но при этом поверить сообщению или звонку, если ситуация выглядит правдоподобно, а запрос поступает от лица знакомой или авторитетной организации. Особенно опасны атаки, в которых злоумышленник заранее собирает информацию о жертве и использует её для создания убедительной легенды.

После выполнения работы я стал внимательнее относиться не только к подозрительным ссылкам и вложениям, но и к самим просьбам о предоставлении информации или выполнении действий. В случае запроса пароля, кода, персональных данных или изменения настроек аккаунта я бы теперь дополнительно проверял личность отправителя через независимый канал. Главный вывод для меня заключается в том, что нельзя считать сообщение безопасным только потому, что оно выглядит убедительно: важны источник информации, контекст запроса и возможность независимо подтвердить его подлинность.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Springer E. Amazon's customer service backdoor [Электронный ресурс]. — URL: <https://medium.com/@espringe/amazon-s-customer-service-backdoor-be375b3428c4> (дата обращения: 18.09.2026).

А АРТЕФАКТЫ

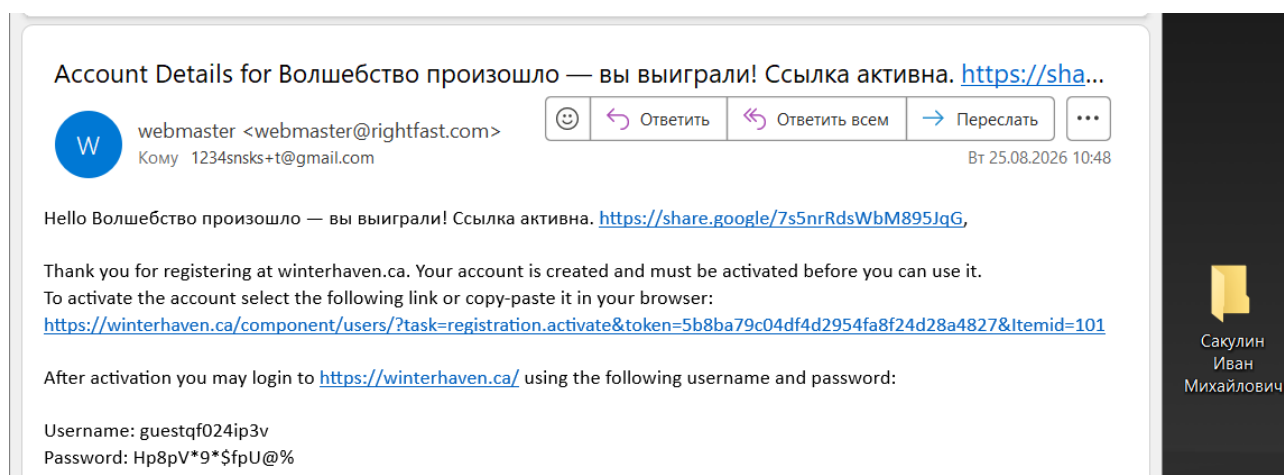


Рисунок А.1 — Письмо-активация аккаунта с внедрённым текстом о выигрыше

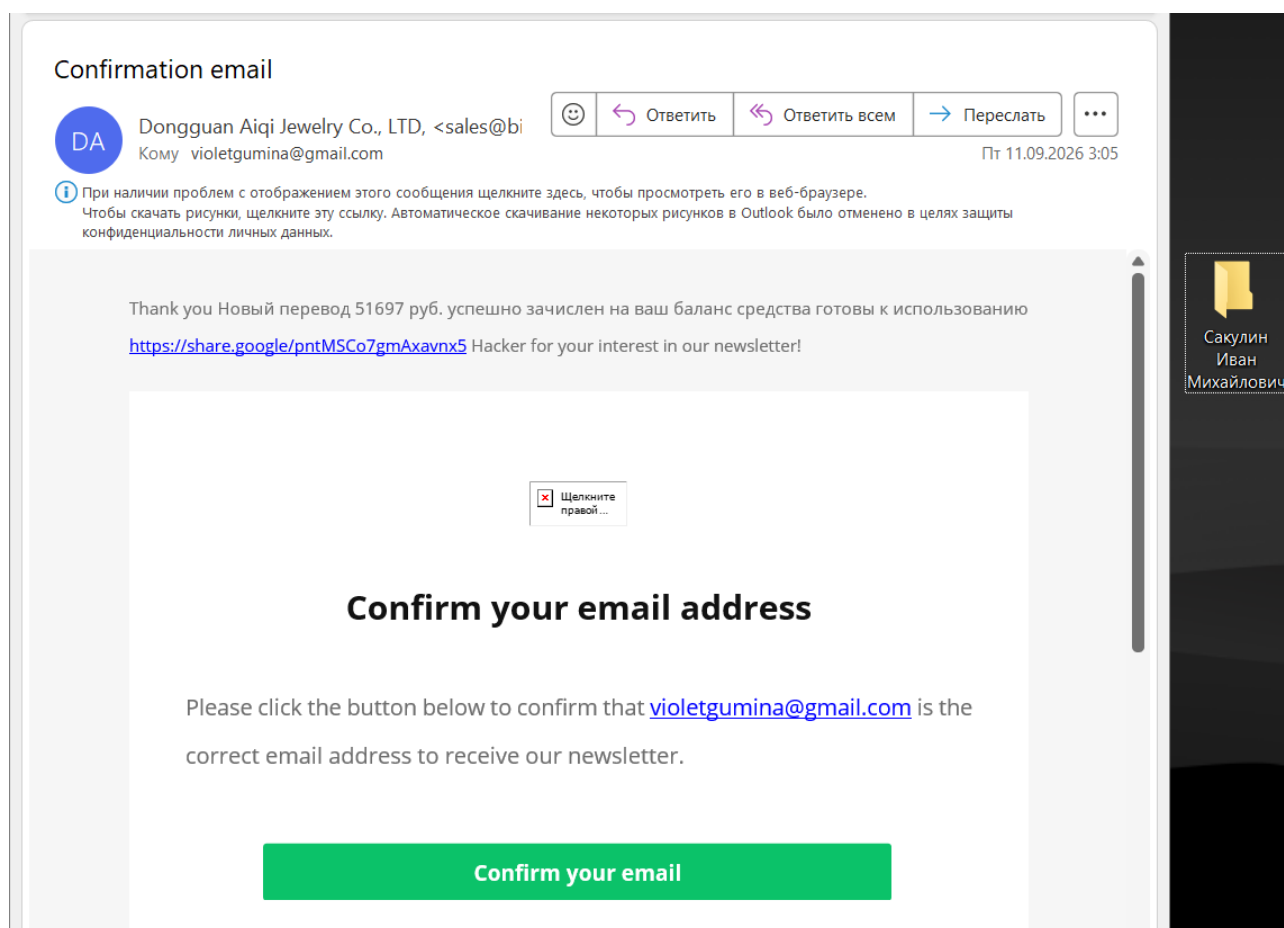


Рисунок А.2 — Рекламная рассылка BioMagneticJewelry

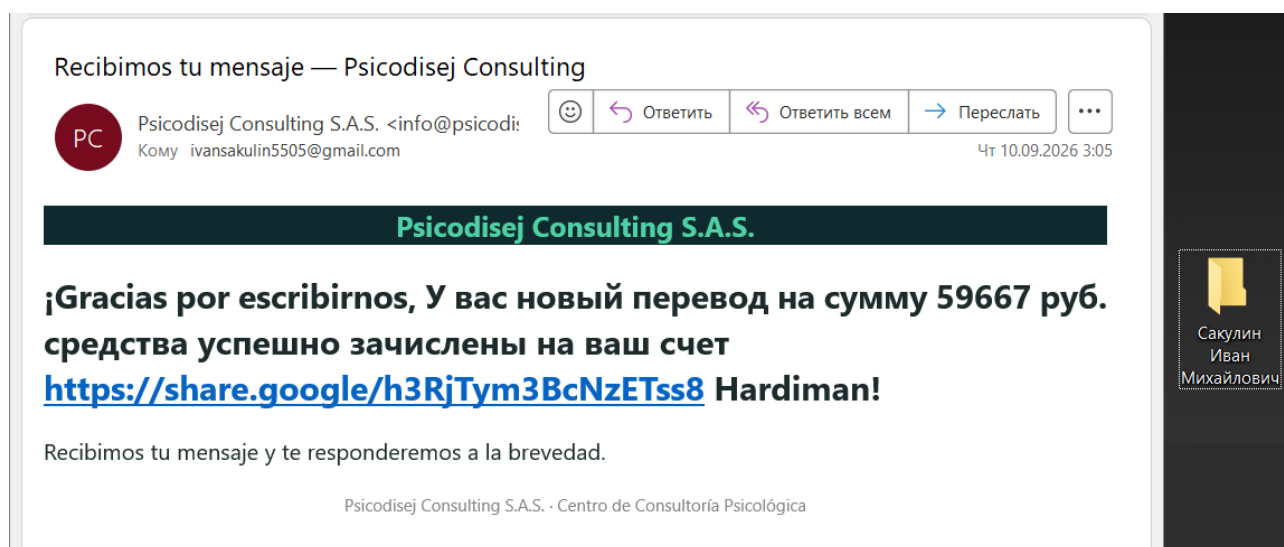


Рисунок А.3 — Автоответ Psicodisej Consulting с внедрённым текстом

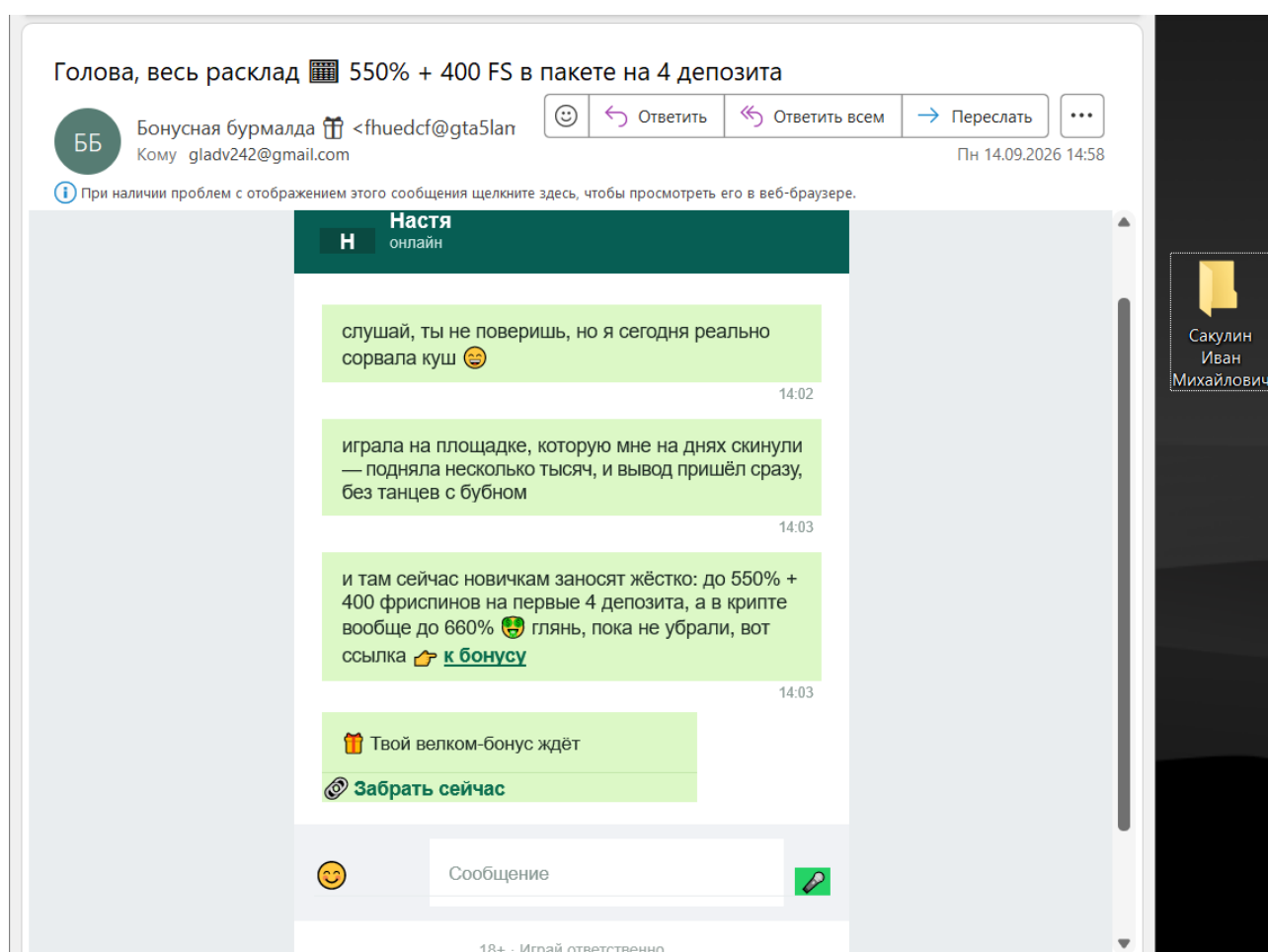


Рисунок А.4 — Сообщение с рекламой казино в формате переписки

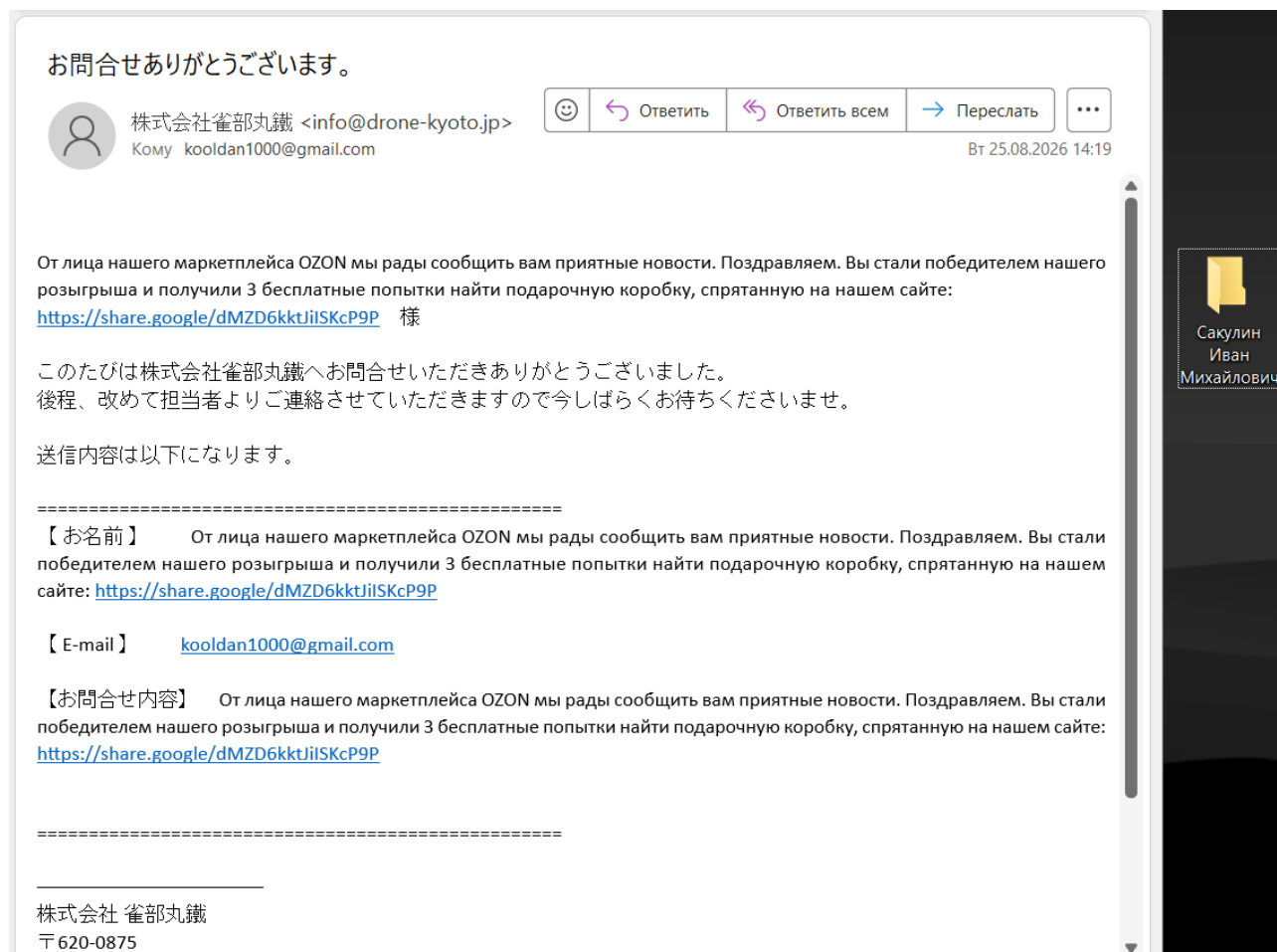


Рисунок А.5 — Автоответ drone-kyoto.jp, первая волна



Рисунок А.6 — Автоответ drone-kyoto.jp, вторая волна

お問合せありがとうございます。



株式会社雀部丸鐵 <info@drone-kyoto.jp>
Кому kooldan1000@gmail.com



Ответить



Ответить всем



Переслать



Ср 19.08.2026 3:44

Команда OZON последний раз напоминает вам что Вы приглашены для участие в денежном розыгрыше среди клиентов нашего маркетплейса. Ваша ссылка-приглашение истечет через 12 часов: <https://share.google/dMZD6kktJilSKcP9P> 様

このたびは株式会社雀部丸鐵へお問合せいただきありがとうございました。
後程、改めて担当者よりご連絡させていただきますので今しばらくお待ちくださいませ。

送信内容は以下になります。

=====

【お名前】 Команда OZON последний раз напоминает вам что Вы приглашены для участие в денежном розыгрыше среди клиентов нашего маркетплейса. Ваша ссылка-приглашение истечет через 12 часов:
<https://share.google/dMZD6kktJilSKcP9P>

【E-mail】 kooldan1000@gmail.com

【お問合せ内容】 Мы рады сообщить вам отличную новость ? вы были выбраны для участия в эксклюзивной акции от OZON. Среди наших клиентов вы стали одним из немногих, кому выпала возможность побороться за невероятные призы:
<https://share.google/dMZD6kktJilSKcP9P>

=====

株式会社 雀部丸鐵
〒620-0875
京都府福知山市字堀2712



Сакулин
Иван
Михайлович

Рисунок А.7 — Автоответ drone-kyoto.jp, третья волна

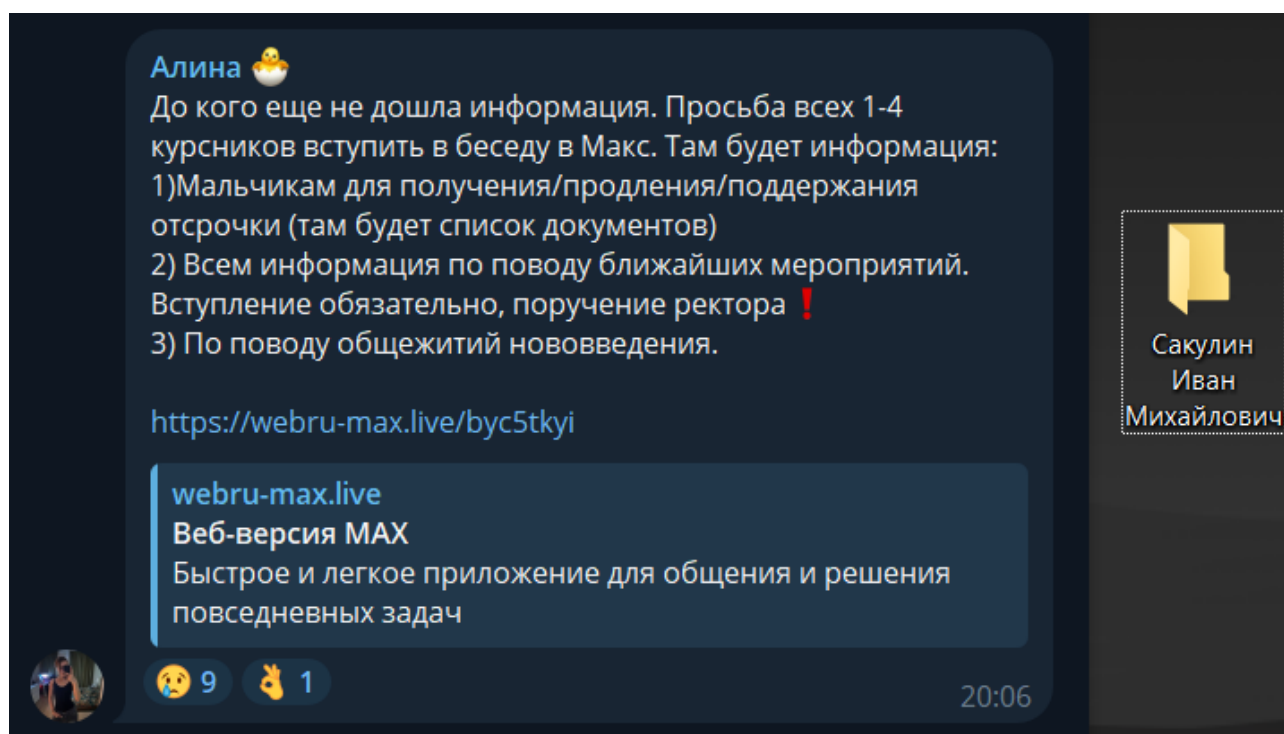


Рисунок А.8 — Сообщение в телеграм-группе общежития